Energy 344 (2026) 140027

Contents lists available at ScienceDirect

Energy

journal homepage: www.elsevier.com/locate/energy

Secure and trustworthy energy systems: A four-layer threat model and defense-in-depth framework

Yuheng Cheng [a], Xiyuan Zhou [b], Huan Zhao [c], Gaoqi Liang [d], Fushuan Wen [e], Junhua Zhao [a,f,*]

[a] School of Science and Engineering, The Chinese University of Hong Kong, Shenzhen, 518172, China
[b] School of Electrical and Electronic Engineering, Nanyang Technological University, Singapore, 639798, Singapore
[c] Department of Building Environment and Energy Engineering, The Hong Kong Polytechnic University, Hong Kong, China
[d] School of Robotics and Advanced Manufacturing, Harbin Institute of Technology, Shenzhen, 518055, China
[e] School of Electrical Engineering, Zhejiang University, Hangzhou, 310027, China
[f] Shenzhen Institute of Artificial Intelligence and Robotics for Society (AIRS), Shenzhen, 518129, China

ARTICLE INFO

Keywords:
Artificial intelligence security
Energy systems
Threat modeling
Defense-in-depth
Large language models
Trustworthy AI
Critical infrastructure protection

ABSTRACT

The integration of artificial intelligence (AI) is fundamentally reshaping energy systems, offering unprecedented capabilities for renewable integration and autonomous operation. However, this transition introduces complex attack surfaces spanning data, model, system, and physical layers. This paper addresses this critical security paradox by reviewing the inherent vulnerabilities of frontier AI paradigms, including deep learning, large language models (LLM), and reinforcement learning (RL) within the energy context. Building on this, we propose a four-layer threat model that goes beyond established risks to analyze how modern paradigms create novel attack vectors. Specifically, we examine how LLMs enable prompt injection and tool abuse that can manipulate physical processes, how RL agents face reward hacking, and how complex data ecosystems are susceptible to sophisticated poisoning attacks targeting foundational knowledge bases. This paper synthesizes cross-disciplinary evidence and provides a structured threat-modeling and defense-in-depth blueprint applicable to both conventional energy AI pipelines (e.g., forecasting and optimization) and emerging LLM-based operational assistants. To counter these evolving threats, we establish a closed-loop defense-in-depth framework that organizes mitigation measures into four pillars: technical protection, data privacy, system architecture, and governance. We map specific defense technologies to corresponding threat layers to provide a practical protection strategy. Looking forward, we envision pathways toward next-generation trustworthy energy AI, highlighting frontier research directions such as online adaptive defense, verifiable AI, and hardware-enhanced confidential computing. We specifically propose the development of red–blue adversarial training and deception defense systems. Ultimately, this paper advocates for deep interdisciplinary collaboration to ensure AI serves as a reliable driver for decarbonization rather than a security liability.

1. Introduction

Artificial intelligence is now a critical component for improving the efficiency, flexibility, and resilience of energy systems, particularly in the context of global climate change and the transition to renewable energy [1,2]. AI enables advanced capabilities across forecasting, optimization, and autonomous control, driving energy systems toward high levels of autonomy and intelligence.

While AI enhances the intelligence of energy systems, it simultaneously introduces unprecedented vulnerabilities due to its dependence on data, model complexity, and decision-making autonomy. This coexistence of empowerment and endangerment constitutes the core security paradox of AI applications in energy systems. AI expands the attack surface from data sources to physical actuators, spanning cyber, physical, and even social dimensions, including previously overlooked elements such as data and model supply chains. Unlike traditional control systems with explicitly programmed rules, AI systems make decisions based on learned patterns, creating vulnerabilities where adversaries can manipulate training data or craft inputs to cause the AI to learn malicious behaviors while appearing to function normally.

Historical cyber–physical attacks on energy infrastructure have demonstrated that cyber attacks can cause severe physical-world consequences [3–5]. Extrapolating to an AI-integrated future, the threat

* Corresponding author at: School of Science and Engineering, The Chinese University of Hong Kong, Shenzhen, 518172, China.
E-mail addresses: yuhengcheng@link.cuhk.edu.cn (Y. Cheng), xiyuan002@e.ntu.edu.sg (X. Zhou), huan-paul.zhao@polyu.edu.hk (H. Zhao), lianggaoqi@hit.edu.cn (G. Liang), fushuan.wen@gmail.com (F. Wen), zhaojunhua@cuhk.edu.cn (J. Zhao).

https://doi.org/10.1016/j.energy.2026.140027
Received 25 November 2025; Received in revised form 24 December 2025; Accepted 11 January 2026
Available online 20 January 2026
0360-5442/© 2026 Published by Elsevier Ltd.

landscape becomes more concerning. Building on foundational concepts like False Data Injection Attacks (FDIA) [6], which traditionally target sensor measurements, attackers can now exploit AI vulnerabilities to launch far more sophisticated attacks that target the cognitive core of the system itself [7]. Instead of merely altering data streams, adversaries can poison external knowledge bases to mislead an LLM's reasoning, manipulate the reward function of an RL agent to instill malicious operational policies, or compromise pre-trained models in the supply chain to implant hidden backdoors. The subtle nature of these AI-specific attacks, which corrupt the model's logic rather than just its input, means that traditional detection systems may fail to identify threats until catastrophic damage has occurred. Current regulatory efforts, including the NIST AI Risk Management Framework [8], MITRE ATLAS [9], NERC CIP standards [10], ISO/IEC 42001 [11], and the European Union AI Act [12], indicate that the governance ecosystem is attempting to keep pace, but significant gaps remain between regulatory requirements and rapidly evolving AI capabilities.

The stakes for AI security in energy systems are extraordinarily high. In power systems with high penetration of renewable energy, reduced system inertia demands extremely fast and precise control, where minor deviations can trigger instability. For instance, a backdoored transient stability assessment or contingency screening model [13,14] could underestimate the post-fault stability margin and delay remedial actions, increasing the risk of loss-of-synchronism events. Similarly, adversarial perturbations or spoofed PMU/SCADA measurements can distort frequency response estimation [15,16], while a prompt-injected dispatcher assistant may recommend inappropriate dispatch or load-shedding actions that deepen the frequency nadir. In protection engineering, compromised AI tools for relay setting calculation or coordination [17] can introduce subtle miscoordination (e.g., incorrect time–current curves or zone settings), causing unintended tripping sequences and accelerating cascading outages. The integration of multiple energy carriers: electricity, gas, heat, and hydrogen, which creates tightly coupled systems where a failure in one domain can propagate to others, triggering cross-domain cascading failures.

The scale of modern distributed energy resources further amplifies these risks. As millions of electric vehicles with vehicle-to-grid capability [18], smart appliances, and other distributed resources connect to the grid through AI agents, a coordinated attack could have devastating impacts on the power system. The distributed and interconnected nature of these resources means that security vulnerabilities can exist at countless endpoints, each potentially serving as an entry point for system-wide attacks. Even commercial multi-energy campuses now rely on AI energy management technologies to orchestrate HVAC, storage, and flexible loads, expanding the operational attack surface beyond traditional utility boundaries [19].

This paper makes several key contributions to the field of AI security in energy systems. First, we propose a four-layer threat model (data, model, system, physical) integrated with energy application scenarios to provide a structured methodology for risk identification. Second, we construct a defense-in-depth framework that integrates technical measures with governance requirements. Third, we analyze novel risks in large language model (LLM)-driven energy operations, including prompt injection and tool abuse. Fourth, we emphasize the role of hardware-assisted security, particularly confidential computing, as a future technical direction.

The remainder of this paper is organized as follows. Section 2 surveys AI applications in energy systems. Section 3 presents our four-layer threat model. Section 4 details defense-in-depth strategies. Section 5 presents a case study of an LLM-based dispatcher assistant. Section 6 explores future research directions. Section 7 concludes the paper.

2. AI in energy systems: Paradigms and inherent vulnerabilities

A comprehensive analysis of AI security threats in energy systems requires a clear understanding of the roles AI fulfills and the vulnerabilities inherent in different AI paradigms. This section establishes the necessary context for the subsequent threat analysis by reviewing core AI paradigms and their security vulnerabilities, with particular attention to frontier technologies like large language models that introduce novel attack vectors.

2.1. Paradigms of artificial intelligence and their inherent vulnerabilities

Different AI paradigms exhibit distinct vulnerabilities rooted in their fundamental learning mechanisms. Supervised and unsupervised learning approaches, which form the foundation of many energy AI applications, are susceptible to data poisoning attacks and adversarial examples due to their absolute dependence on training data. Reinforcement learning (RL) introduces reward hacking and state observation attack risks, as attackers can tamper with environmental feedback to deceive RL agents into learning malicious policies [20,21]. Physics-informed neural networks (PINNs) [22,23] face physical deception challenges when data integrity or model fidelity is compromised, potentially producing outputs that appear physically plausible but are fundamentally incorrect. Industrial-scale AI energy management deployments already integrate load forecasting with fault prediction, underscoring how operational AI stacks have become tightly coupled and high-stakes [24].

LLMs [25] introduce unique risks that are particularly relevant to energy systems. Prompt injection attacks can hijack the model's behavior, and when granted tool-use capabilities (e.g., APIs), this escalates into tool abuse, transforming text-based attacks into direct physical threats. LLMs are also prone to factual incorrectness (hallucination), which is particularly dangerous in high-risk energy system operations where incorrect advice could have catastrophic consequences.

2.2. AI in energy operations

AI integration in energy systems has evolved from specific functional modules to increasingly autonomous agents. Conventional energy AI pipelines, such as load forecasting, optimal power flow (OPF), and state estimation, are already deeply embedded in grid operations. These systems generally follow a structured processing flow: data ingestion, inference/optimization, and control action. However, they are inherently vulnerable to adversarial data manipulation, model backdoors, and diverse integrity attacks. For instance, a compromised forecasting model can mislead generation scheduling, while a backdoored OPF solver could trigger uneconomic or unsafe dispatch.

LLMs represent a new frontier, introducing open-ended interaction and agentic capabilities. Unlike fixed-function conventional pipelines, LLMs can interpret unstructured data, reason about complex scenarios, and potentially invoke tools (e.g., SCADA APIs) directly. This introduces novel risks: prompt injection attacks can hijack the model's reasoning, and tool abuse can transform textual manipulation into physical control actions. Furthermore, hallucination in LLMs poses unacceptable safety risks in critical infrastructure.

Despite these differences in modality, both conventional pipelines and emerging LLM agents [26] share a fundamental vulnerability structure: attacks can originate from data sources, compromise the model's logic, hijack the system integration, and propagate to physical assets. To systematically analyze these cross-cutting risks, we propose a unified Four-Layer Threat Model in the following section.

3. A four-layer AI security threat model

To systematically address the risks introduced by AI, this section proposes a layered threat model, shown in Fig. 1. The adoption of highly interactive and autonomous paradigms like LLMs and multi-agent systems necessitates this structured approach, as threats are no longer isolated incidents but can form complex, cross-layer propagation chains. For example, a malicious natural language prompt (originating in the Data Layer) can hijack a model's reasoning process (manifesting

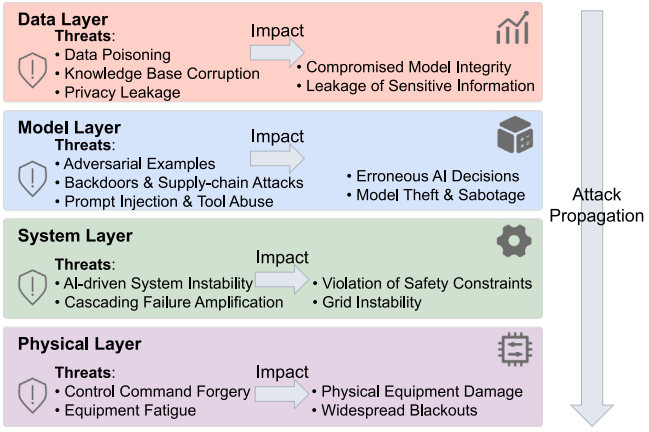


Fig. 1. The Four-Layer Threat Model for AI in Energy Systems, illustrating the escalation of threats from the data foundation to physical consequences. The diagram shows the types of threats pertinent to each layer and an example of an attack propagating through the entire stack.

in the Model Layer), lead to unauthorized API calls (exploiting the System Layer), and ultimately trigger a physical blackout (impacting the Physical Layer). This four-layer model provides an essential framework to deconstruct and analyze these intricate attack paths, from digital inception to physical consequence.

Classification Rationale Our layering is defined by the *protection object*—the specific component or asset that is the direct target of security measures within each layer. This object-oriented boundary definition provides a clear semantic distinction: an attack's *origin* (where it is introduced) may differ from its *effect* (where it manifests and causes harm). For example, data poisoning originates at the data layer but manifests its effect, such as an implanted backdoor, at the model layer during inference. This origin-effect distinction is critical for designing targeted defenses and understanding attack propagation paths across layers, as detailed in Sections 3.1 through 3.5 and illustrated in Table 2.

Our framework complements established security models. The Purdue Model [27] focuses on network segmentation but does not adequately address threats originating within the AI software stack. MITRE ATT&CK for ICS [28] and MITRE ATLAS for AI [9] provide comprehensive taxonomies of attacker tactics, techniques, and procedures (TTPs) but primarily from the attacker's perspective. The novelty of our four-layer model lies in its focus on the AI-centric, cyber–physical attack path, bridging a critical gap between AI security research and energy system protection (see Table 1). Note that the proposed four-layer model is intended as a threat-modeling and propagation lens rather than an automated detector. For instance, an indirect prompt injection in an LLM-based dispatcher assistant can evolve into unauthorized SCADA/EMS API calls and ultimately unsafe OT operations, spanning all four layers; this end-to-end propagation is not captured when the Purdue Model, MITRE ATLAS, or MITRE ATT&CK for ICS are used in isolation.

3.1. Defining the layer boundaries

To provide a clear analytical framework, we define the boundaries and protection objects of each layer:

The Data Layer encompasses the entire lifecycle of data used by the AI, including collection, transmission, storage, and pre-processing. The protection object is the training and inference data itself. Threats at this layer compromise the data's integrity, confidentiality, or availability before it is consumed by the model for training or inference.

The Model Layer pertains to the AI model itself, including its architecture, parameters, and the inference process. The protection object is the model's logic and learned representations. Attacks here target the model's internal logic to manipulate its behavior and outputs. While some model-layer threats like backdoors may be implanted via data-layer attacks (i.e., data poisoning), the vulnerability itself resides and is triggered within the model during operation.

The System Layer involves the integration of the AI model into the broader operational software and hardware stack. The protection object is the AI-system integration, including APIs, communication protocols, operating systems, and surrounding workflow logic. Threats at this layer exploit the interactions between the AI component and the larger system to cause unintended consequences.

The Physical Layer represents the tangible machinery and infrastructure that the AI system monitors or controls. The protection object is the actuators and energy equipment. This is the domain where cyber-attacks manifest as real-world physical events, such as equipment damage or power outages.

Attack paths can propagate across these layers, where a compromise at one layer enables or causes compromise at subsequent layers. For example, a data poisoning attack can implant a backdoor in the model layer, which then generates erroneous decisions affecting the system layer, ultimately causing physical consequences. The systematic analysis of such cross-layer propagation is illustrated in Table 2.

3.2. Data layer threats

The data layer constitutes the foundation of AI models. As the *protection object* of this layer is training and inference data, attacks here aim to compromise data integrity, authenticity, or privacy before it is consumed by the model.

The primary threat is **data poisoning** (*origin*: Data Layer → *effect*: Model Layer), where an attacker maliciously injects carefully crafted data into the training set [29]. The attack originates by corrupting the training data, but its effect, such as degraded model performance or an implanted backdoor, manifests in the model layer during inference. For LLMs that use Retrieval-Augmented Generation (RAG) [30] to access external knowledge, an attacker can poison the knowledge base itself. For instance, by subtly altering the maximum thermal limits of a transformer in a digital operational manual, causing the LLM to provide dangerously flawed advice.

3.3. Model layer threats

The model layer contains the core logic of the AI system. As the *protection object* of this layer is the model's architecture, parameters, and inference logic, attacks here focus on compromising the model's integrity, robustness, or confidentiality.

Backdoor attacks (*origin*: Data Layer/Model supply chain → *effect*: Model Layer) create a hidden "trigger-target" behavior within the model [31,32]. The backdoor may be implanted through data poisoning during training or introduced via compromised pre-trained weights from the model supply chain. The compromised model functions normally until a specific, attacker-defined trigger in the inference input activates the backdoor, forcing a malicious output. For example, a pre-trained grid topology identification model downloaded from a third-party repository could contain a backdoor that causes it to falsely report a critical transmission line as disconnected when a specific, benign-looking voltage fluctuation pattern appears.

The rise of LLMs introduces **prompt injection** attacks [33–35], where attackers craft natural language inputs to bypass safety guardrails and manipulate the model's reasoning. The ultimate danger lies in hijacking the model's authorized capabilities: by embedding malicious instructions within an ostensibly benign query, an attacker can commandeer the LLM, forcing it to execute unauthorized external tool calls (e.g., invoking SCADA APIs to open a circuit breaker). This effectively weaponizes the LLM, transforming it from a passive assistant into an active threat agent, thereby escalating a model-layer vulnerability directly into a system-layer compromise known as *tool abuse*.

Table 1
Comparison of the proposed 4-layer threat model with existing security frameworks.

Framework	Core focus	Differentiator	Limitation
Proposed 4-Layer Model	AI-centric cyber–physical attack path propagation.	Maps AI vulnerabilities (data/model) to physical impact; Bridges AI & OT security.(e.g., prompt injection → tool abuse → OT command)	Conceptual model(threat-modeling lens); requires specific TTPs for attack simulation.
Purdue Model [27]	Network segmentation & hierarchical zones (IT/OT).	Foundational for network architecture security.	Assumes trust within zones; not designed for software/data supply chain threats.
MITRE ATT&CK for ICS [28]	Adversary TTPs against industrial control systems.	Comprehensive knowledge base of OT attacker TTPs.	Lacks focus on AI-specific vulnerabilities; describes "how" not the full AI "cause-to-effect" chain.
MITRE ATLAS [9]	Adversary TTPs against ML systems.	Most relevant knowledge base for AI-specific TTPs.	Primarily digital domain; lacks structured connection to physical-layer impacts.

Table 2
Threat classification based on the four-layer model. Threats are categorized by the primary protection object they target, illustrating how compromises can propagate across layers.

Threat layer	Threat type	Description & Propagation mechanism
Data Layer	Privacy Leakage/Model Inversion	Exploiting model outputs to reverse-engineer sensitive training data. The primary harm is the breach of **data confidentiality**.
Model Layer	Adversarial Examples	Crafting malicious inference-time inputs to exploit **model decision boundaries**. *Attack originates at the input data stream but manifests in the model layer.*
	Data Poisoning/Backdoor Attack	Corrupting training data (e.g., sensor logs, knowledge bases) to embed hidden, malicious behaviors within the **model's logic**. *Effect propagates to the System Layer via flawed decisions.*
	Supply-chain Compromise	Using maliciously modified pre-trained models or libraries to compromise the **model's integrity** before deployment.
	Prompt Injection	Hijacking an LLM's reasoning process with malicious text inputs, compromising the **model's intended logic**. *Can propagate to the System Layer as Tool Abuse.*
System Layer	Tool Abuse/API Hijacking	A compromised model exploits its authorized API access to execute unauthorized operations, attacking the AI-system integration.
	Systemic Instability/Cascading Failure	Erroneous AI decisions or flawed multi-agent coordination cause system-wide failures, compromising the **operational workflow's stability**.
Physical Layer	Command Forgery/Tampering	Intercepting or forging commands sent to actuators, directly causing incorrect actions and harming **physical equipment**.
	Covert Equipment Fatigue (Low-and-Slow Attack)	Inducing subtle, persistent manipulations that cause frequent minor adjustments, leading to accumulated mechanical wear and premature failure of **physical assets**.

3.4. System layer threats

The system layer is where AI models are integrated into broader operational workflows and business processes, functioning as the core decision-making and control hub. As the *protection object* of this layer is the integration of AI with APIs, communication protocols, and control workflows, attacks here manipulate the AI-driven logic to cause systemic dysfunction.

When **prompt injection** escalates to **tool abuse** (*origin*: Model Layer → *effect*: System Layer), a compromised LLM exploits its authorized API interfaces to execute unauthorized operations, manipulating system-level logic. For example, an attacker could manipulate an LLM-based dispatcher assistant to call a SCADA API function that opens a critical circuit breaker, bypassing normal operational procedures. In tightly coupled, multi-agent energy systems, erroneous AI decisions can also propagate and be amplified by other AI agents, creating cascading failures [36,37]. Recent cyber-tolerant control studies already treat deception and periodic denial-of-service attacks as first-class contingencies for renewable-integrated frequency regulation, underscoring how system-layer safeguards must anticipate persistent adversarial pressure [38].

3.5. Physical layer threats

The physical layer is the ultimate target of an attack, where AI decisions are enacted by actuators like circuit breakers, valves, and inverters to effect change in the physical world. As the *protection object* of this layer is actuators and energy infrastructure, attacks here aim to cause tangible equipment damage or disrupt the energy supply [39,40].

A more insidious threat is **covert equipment fatigue, or "low-and-slow", attacks** (*origin*: Data or Model Layer → *effect*: Physical Layer). Instead of causing immediate, obvious damage, the attacker aims for stealthy, long-term degradation of physical assets. By feeding minor, persistent perturbations into an AI's sensor inputs (data layer) or subtly manipulating the model's decision logic (model layer), an attacker can induce it to make frequent, small, and seemingly unnecessary adjustments to physical equipment, such as transformer tap changers or generator excitation systems. While each individual adjustment remains within safe operational parameters, the cumulative effect over time accelerates mechanical wear and electrical stress, drastically shortening the equipment's lifespan and leading to a premature, seemingly natural failure.

Table 3
Threat-Defense Mapping Matrix. This table illustrates the defense-in-depth strategy by showing which defensive measures are effective against the threats identified in the four-layer model. A checkmark (✓) indicates a primary mitigation relationship. Abbreviations: *Input Sanit.*: Input Sanitization; *Adv. Train.*: Adversarial Training; *Conf. Comp.*: Confidential Computing; *Backdoor Det.*: Backdoor Detection; *Data Integ.*: Data Integrity & Provenance; *PETs*: Privacy Enhancing Technologies; *Sec. MLOps*: Secure MLOps & Red Teaming.

Threat layer & Type	Technical protections				Data & Privacy		System & Arch.		Gov.
	Input Sanit.	Adv. Train.	Conf. Comp.	Backdoor Det.	Data Integ.	PETs	Zero Trust	N-1-AI	Sec. MLOps
Data Layer: Data Poisoning	✓			✓	✓				✓
Data Layer: Privacy Leakage			✓			✓			
Model Layer: Adversarial Examples	✓	✓						✓	
Model Layer: Backdoors & Supply Chain				✓	✓				✓
Model Layer: Prompt Injection	✓						✓		✓
System Layer: Tool Abuse/API Hijack							✓	✓	✓
System Layer: AI-driven Instability							✓	✓	✓
Physical Layer: Command Forgery							✓		
Physical Layer: Covert Equip. Fatigue							✓		✓

4. A defense-in-depth framework for energy AI

Following the systematic analysis of threats across four distinct layers, this section proceeds to construct a comprehensive defense. Effective AI security requires a defense-in-depth strategy rather than single-point solutions. We detail mitigation measures across four dimensions: technical, data, system, and governance, which are mapped to the threat model in Table 3.

Effective defense requires multi-layered, reinforcing measures deployed across the entire AI-energy system stack. While our threat model is organized by *protection objects* (data, model, system, physical), our defense framework is organized by *defense mechanisms and responsibilities*, as certain protective measures cut across multiple threat layers. For instance, confidential computing protects both model integrity (Model Layer) and data privacy (Data Layer), while governance practices establish security requirements across all layers. This orthogonal organization ensures comprehensive coverage, as illustrated in Table 3. We organize defenses into four pillars:

Pillar 1: Technical Protections for AI Models. These measures strengthen the robustness and integrity of AI models against adversarial manipulation. Adversarial training and robust optimization improve model resilience [29]. Model signing and integrity verification use digital signatures to prevent unauthorized tampering. Model and weight encryption, combined with confidential computing in Trusted Execution Environments (TEE) [41–43], protect model confidentiality and integrity at the hardware level. Backdoor detection and removal techniques identify and neutralize hidden backdoors in models.

Pillar 2: Data and Privacy Protections. These measures secure the data sources that AI relies upon. Data integrity verification and provenance ensure the integrity and traceability of critical training and sensor data. Differential privacy protects against membership inference and model inversion attacks [44]. Federated learning allows models to be trained on decentralized data without exposing raw data, with secure aggregation protocols to mitigate gradient poisoning [45,46].

Pillar 3: System and Architectural Security. These measures create trusted operating environments and ensure resilience against system-level and physical-layer threats. A Zero Trust Architecture in the AI context means strict verification for every AI model's API access, preventing tool abuse in LLM-driven systems through heterogeneous model deployment (heterogeneous redundancy). Real-time monitoring of AI model health and behavior is crucial, with metrics tailored to each AI paradigm.

A key principle for system resilience is the **N-1-AI principle**, which extends the traditional N-1 criterion from power systems to the AI decision-making layer. The core is **heterogeneity**, not simple redundancy: deploying diverse models (e.g., a deep learning model alongside a classical expert system) to minimize the risk of a single attack vector causing "common-mode failure" across all decision systems. Unlike traditional physical N-1 contingencies, cyber and AI components may fail in a correlated manner due to shared software stacks, communication protocols, model supply chains, or cloud dependencies. Therefore, the practical goal of N-1-AI is to avoid common-mode failures by defining independent failure domains and ensuring that at least one decision channel remains trustworthy under a realistic attacker model. In implementation, heterogeneity can be selectively enforced across model families (e.g., deep learning/PINN/RL vs. rule-based or physics-based solvers), training data sources, feature pipelines, and software/hardware stacks, with independent update and signing processes to reduce shared supply-chain risk. Full end-to-end heterogeneity is often impractical; a cost-aware implementation can keep standardized protocols but diversify critical implementations and strengthen isolation, patch management, and runtime monitoring. A lightweight arbitration module can monitor model confidence and inter-model disagreement; switching triggers can include confidence collapse, disagreement beyond a threshold, detection of anomalous inputs or policy violations in tool-use requests. Effectiveness can be evaluated by reductions in attack success rate, time-to-detect and time-to-switch, the resulting physical performance, and additional end-to-end latency to ensure real-time feasibility. For physical layer protection, command authentication and rate limiting at actuators, combined with physical interlocks and safety instrumented systems (SIS), provide an independent, non-AI-based layer that can override dangerous commands.

Pillar 4: Governance and Regulation. These measures establish secure development lifecycles and compliance processes. Secure MLOps embeds security requirements throughout the AI lifecycle, including vulnerability scanning, model inventory management (SBOM for AI), and regular AI red-teaming exercises. In practical grid environments,

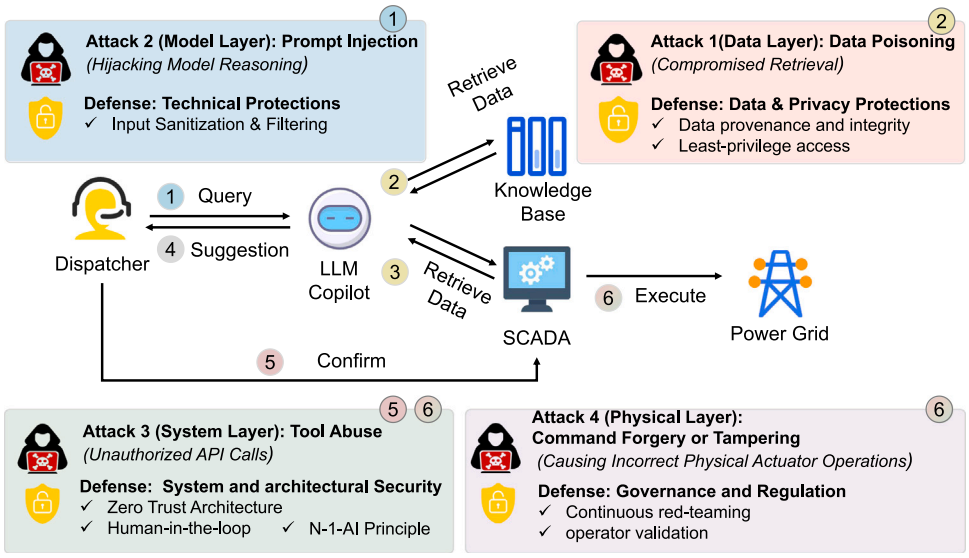


Fig. 2. Architecture and Threat Vectors for an LLM-based Dispatcher Assistant. The numbered black arrows show the normal sequence of operations. The red arrows and callouts illustrate how an attacker can leverage different threat vectors corresponding to the layers of our model to compromise the system.

these practices can be integrated into legacy cybersecurity compliance programs such as NERC CIP. For example, Zero Trust authorization for AI tool-use interfaces complements access control requirements (e.g., CIP-005/007); model/version integrity verification and change management align with CIP-010; protection of sensitive training data and operational logs aligns with CIP-011; and model SBOMs, signed weights, and vetted third-party libraries support supply chain risk management (CIP-013). Compliance with standards like the NIST AI Risk Management Framework [8], ISO/IEC 42001 [11], and the EU AI Act [12] ensures adherence to best practices and provides accountability structures.

5. Case study: An LLM-based dispatcher assistant

To illustrate our framework, this section presents a case study on an LLM-based intelligent copilot for power system dispatchers. We analyze an LLM integrated with domain-specific knowledge bases via RAG, capable of querying real-time grid status via SCADA APIs, analyzing alarms, and generating operational recommendations. Fig. 2 illustrates the system's architecture and threat vectors.

In this LLM assistant scenario, attackers can exploit vulnerabilities across all four layers: **(1) Data Layer**: poisoning the external knowledge base to alter critical operational parameters; **(2) Model Layer**: embedding prompt injection attacks to hijack the LLM's reasoning process; **(3) System Layer**: exploiting authorized API access for tool abuse, enabling unauthorized SCADA commands; **(4) Physical Layer**: malicious commands propagate to physical actuators, causing circuit breakers to trip incorrectly and destabilizing the grid. This multi-layer attack path, which range from prompt injection (Model Layer) through API hijacking (System Layer) to physical consequences (Physical Layer), demonstrates the critical need for defense-in-depth.

To facilitate reproducible evaluation, a conceptual simulation setup can be constructed as follows: (i) select a representative distribution feeder (e.g., IEEE 33-bus) and simulate quasi-static power flow in OpenDSS, or select a representative transmission test system (e.g., IEEE 39-bus) and simulate transients in a dynamic simulator; (ii) use a co-simulation orchestrator (e.g., HELICS or a digital-twin platform [47, 48]) to couple the power simulator with a mocked SCADA/EMS API; (iii) let the LLM assistant ingest alarms and query a RAG knowledge base, then generate recommendations and tool-use requests through the API; and (iv) emulate an attacker that injects malicious prompts or poisons retrieved documents. Key evaluation metrics include frequency nadir and recovery time, transient stability margin, relay misoperation rate, and the rate of unsafe tool calls blocked by policy enforcement.

To provide a minimal proof-of-concept numerical illustration, we conducted a steady-state simulation on the IEEE 33-bus distribution network using Pandapower. As shown in Fig. 3 and Table 4, we compared four scenarios: (A) a well-optimized baseline with reactive power compensation; (B) an AI load forecast error leading to 80% higher actual load; (C) an AI-advised erroneous capacitor removal combined with a 50% load surge; and (D) a combined multi-layer attack. The results demonstrate that AI-induced errors can significantly degrade voltage profiles: the baseline scenario maintains all 33 buses within acceptable voltage limits (minimum voltage 0.971 p.u.), while the combined attack scenario (D) causes 21/33 buses to violate voltage limits with the minimum voltage dropping to 0.904 p.u. and network losses increasing by nearly 500%. These quantitative results validate the physical-layer impacts described in our threat model.

Securing this system requires addressing each layer: **Technical protections** include strict input filtering and output validation. **Data and privacy protections** enforce data provenance and integrity checks on knowledge bases. **System and architectural security** implements Zero Trust with heterogeneous model deployment (N-1-AI principle) and independent authentication for API calls. **Governance and regulation** establish continuous AI red teaming and clear operational procedures prohibiting unconditional trust in AI-generated advice.

6. Future research directions

While the proposed defense-in-depth framework can mitigate known threats, the rapid evolution of AI requires ongoing research. This section outlines a blueprint for future work in energy AI security.

Future research must focus on enhancing the intrinsic resilience and trustworthiness of AI models. A key direction is adaptive and self-healing security, moving beyond static defenses to create AI frameworks capable of autonomous threat response. These systems would be capable of online detection of novel attack patterns and could automatically trigger model retraining or switch to safe backup strategies. Another critical area is auditable and verifiable AI. The "black box" nature of many models makes it difficult to audit their decisions or formally prove their safety. Future work should focus on establishing explainable evidence chains for model decisions [49,50] and using formal verification to prove that model outputs will remain within predefined safety envelopes [51]. Finally, performance-security co-design

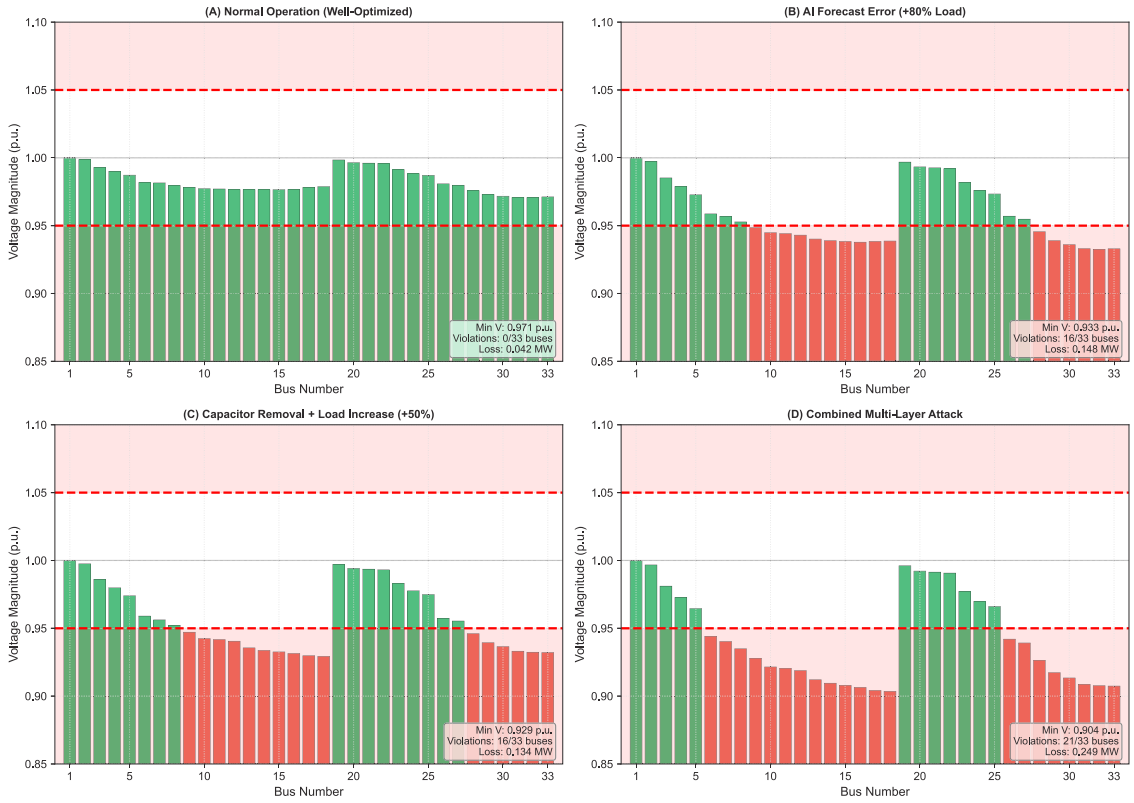


Fig. 3. Voltage profiles of the IEEE 33-bus network under different AI-induced error scenarios. Green bars indicate buses with voltage within acceptable limits (0.95–1.05 p.u.); red bars indicate undervoltage violations (below 0.95 p.u.). (A) Well-optimized baseline with zero violations. (B) AI forecast error with +80% load leads to 16/33 violations. (C) Erroneous capacitor removal causes 16/33 violations. (D) Combined attack shows the most severe degradation with 21/33 violations and minimum voltage at 0.904 p.u.

Table 4
Quantitative impact of AI-induced errors on IEEE 33-bus network.

Scenario	Min V (p.u.)	Violations	Max Dev (%)	Loss (MW)
(A) Baseline (Well-Optimized)	0.971	0/33	2.9	0.042
(B) AI Forecast Error (+80%)	0.933	16/33	6.7	0.148
(C) Capacitor Removal (+50%)	0.929	16/33	7.1	0.134
(D) Combined Multi-Layer Attack	0.904	21/33	9.6	0.249

is essential. Many security measures introduce computational overhead, which can be unacceptable in real-time energy applications. Research should explore hardware–software co-design to minimize this impact, such as optimizing AI operations on confidential computing platforms (TEE + GPU/FPGA).

A second major research thrust is to shift from a reactive to a proactive and collaborative security posture. This includes developing advanced multimodal and cross-domain defense systems. The future vision is a "digital twin" security analysis engine that fuses multimodal data from physical sensors (PMU, SCADA), network telemetry, and IT system logs, allowing AI to correlate heterogeneous data streams to detect complex, coordinated attacks. This leads to proactive defense and threat intelligence. Defenders are typically in a passive posture, but future systems should incorporate active defense concepts. This system uses honeytokens, honeypots, and honeynets to lure, monitor, and analyze attackers, providing early warnings and actionable threat intelligence. To validate these strategies, AI red teaming and testbeds are required. A safe, high-fidelity environment for testing AI attack and defense techniques is currently lacking. Future work must focus on developing dedicated digital twin or hardware-in-the-loop testbeds that integrate power system simulation, network emulation, and AI attack-defense toolchains, allowing red and blue teams to conduct continuous adversarial exercises.

7. Conclusion

This paper has examined the dual role of AI in the energy transition, as both a powerful enabler and a potential source of security risks. We have proposed a security paradigm that integrates a four-layer threat model and a defense-in-depth framework. Our paradigm covers the full chain of threats from the data to the physical layer and organizes countermeasures across technical, architectural, and governance dimensions, including the unique risks of frontier AI technologies like LLMs.

This paper emphasizes that AI security in critical infrastructure such as energy systems must be treated as a foundational property rather than a secondary consideration. The research agenda proposed here, which includes adaptive security, verifiable AI, and hardware–software co-design, aims to guide future work. Collaborative efforts between experts in energy engineering, AI, cybersecurity, and policy are essential for establishing the standards and best practices needed to ensure that AI is a robust, reliable, and trustworthy foundation for the future Energy Internet.

CRediT authorship contribution statement

Yuheng Cheng: Writing – original draft, Formal analysis, Data curation, Conceptualization. **Xiyuan Zhou:** Visualization, Software.

Huan Zhao: Methodology, Investigation. **Gaoqi Liang:** Validation, Supervision. **Fushuan Wen:** Supervision, Methodology. **Junhua Zhao:** Project administration, Funding acquisition, Conceptualization.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This work was supported by the National Natural Science Foundation of China (Grant Number: 72331009, 72171206, and 92270105) and the Shenzhen Key Laboratory of Crowd Intelligence Empowered Low-Carbon Energy Network (Grant Number: ZDSYS20220606100601002).

Data availability

Data will be made available on request.

References

[1] Chen Changming, Liang Hongle, Zhai Xingli, Zhang Jinai, Liu Shengyuan, Lin Zhenzhi, Yang Li. Review of restoration technology for renewable-dominated electric power systems. Energy Convers Econ 2022;3(5):287–303.
[2] Chen Dongyu, Lin Xiaojie, Qiao Yiyuan. Perspectives for artificial intelligence in sustainable energy systems. Energy 2025;318:134711.
[3] Liang Gaoqi, Weller Steven R, Zhao Junhua, Luo Fengji, Dong Zhao Yang. The 2015 Ukraine blackout: Implications for false data injection attacks. IEEE Trans Power Syst 2016;32(4):3317–8.
[4] Kimani Kenneth, Oduol Vitalice, Langat Kibet. Cyber security challenges for IoT-based smart grid networks. Int J Crit Infrastruct Prot 2019;25:36–49.
[5] Wang Qin, Zhang Guangyuan, Wen Fushuan. A survey on policies, modelling and security of cyber-physical systems in smart grids. Energy Convers Econ 2021;2(4):197–211.
[6] Liu Yao, Ning Peng, Reiter Michael K. False data injection attacks against state estimation in electric power grids. ACM Trans Inf Syst Secur (TISSEC) 2011;14(1):1–33.
[7] Ruan Jiaqi, Liang Gaoqi, Zhao Junhua, Zhao Huan, Qiu Jing, Wen Fushuan, Dong Zhao Yang. Deep learning for cybersecurity in smart grids: Review and perspectives. Energy Convers Econ 2023;4(4):233–51.
[8] NIST AI. Artificial intelligence risk management framework (AI RMF 1.0). 2023, URL: https://nvlpubs.nist.gov/nistpubs/ai/nist.ai, p. 100–1.
[9] MITRE Corporation. ATLAS: Adversarial threat landscape for artificial-intelligence systems. 2023, https://atlas.mitre.org/.
[10] North American Electric Reliability Corporation. Critical Infrastructure Protection (CIP) reliability standards, version 7. Technical report, NERC; 2023.
[11] International Organization for Standardization. ISO/IEC 42001: 2023-information technology-artificial intelligence-management system. 2023.
[12] Smuha Nathalie A. Regulation 2024/1689 of the Eur. Parl. & Council of june 13, 2024 (EU artificial intelligence act). Int Leg Mater 2025;1–148.
[13] James JQ, Hill David J, Lam Albert YS, Gu Jiatao, Li Victor OK. Intelligent time-adaptive transient stability assessment system. IEEE Trans Power Syst 2017;33(1):1049–58.
[14] Zhu Lipeng, Hill David J, Lu Chao. Hierarchical deep learning machine for power system online transient stability prediction. IEEE Trans Power Syst 2019;35(3):2399–411.
[15] Chen Yize, Tan Yushi, Zhang Baosen. Exploiting vulnerabilities of load forecasting through adversarial attacks. In: Proceedings of the tenth ACM international conference on future energy systems. 2019, p. 1–11.
[16] Olowononi Felix O, Rawat Danda B, Liu Chunmei. Resilient machine learning for networked cyber physical systems: A survey for machine learning security to securing machine learning for CPS. IEEE Commun Surv & Tutorials 2020;23(1):524–52.
[17] Xu Hanchen, Domínguez-García Alejandro D, Sauer Peter W. Data-driven coordination of distributed energy resources for active power provision. IEEE Trans Power Syst 2019;34(4):3047–58.
[18] Liu Hui, Hu Zechun, Song Yonghua, Wang Jianhui, Xie Xu. Vehicle-to-grid control for supplementary frequency regulation considering charging demands. IEEE Trans Power Syst 2014;30(6):3110–9.
[19] Fu Zhong-Lin, Cao Can, Gao Feng. Impact of artificial intelligence energy management technologies on commercial multi-energy consumption. Energy 2025;139247.
[20] Zhang Zidong, Zhang Dongxia, Qiu Robert C. Deep reinforcement learning for power system applications: An overview. CSEE J Power Energy Syst 2019;6(1):213–25.
[21] Zhou Yanting, Ma Zhongjing, Zhang Jinhui, Zou Suli. Data-driven stochastic energy management of multi energy system using deep reinforcement learning. Energy 2022;261:125187.
[22] Raissi Maziar, Perdikaris Paris, Karniadakis George E. Physics-informed neural networks: A deep learning framework for solving forward and inverse problems involving nonlinear partial differential equations. J Comput Phys 2019;378:686–707.
[23] Misyris George S, Venzke Andreas, Chatzivasileiadis Spyros. Physics-informed neural networks for power systems. In: 2020 IEEE power & energy society general meeting. IEEE; 2020, p. 1–5.
[24] Hu Yusha, Li Jigeng, Hong Mengna, Ren Jingzheng, Man Yi. Industrial artificial intelligence based energy management system: Integrated framework for electricity load forecasting and fault prediction. Energy 2022;244:123195.
[25] Naveed Humza, Khan Asad Ullah, Qiu Shi, Saqib Muhammad, Anwar Saeed, Usman Muhammad, Akhtar Naveed, Barnes Nick, Mian Ajmal. A comprehensive overview of large language models. ACM Trans Intell Syst Technol 2025;16(5):1–72.
[26] Cheng Yuheng, Zhang Ceyao, Zhang Zhengwen, Meng Xiangrui, Hong Sirui, Li Wenhao, Wang Zihao, Wang Zekai, Yin Feng, Zhao Junhua, et al. Exploring large language model based intelligent agents: Definitions, methods, and prospects. 2024, arXiv preprint arXiv:2401.03428.
[27] Williams Theodore J. The purdue enterprise reference architecture. Comput Ind 1994;24(2–3):141–58.
[28] MITRE Corporation. MITRE ATT&CK for industrial control systems. 2023, https://attack.mitre.org/matrices/ics/.
[29] Hao Jingbo, Tao Yang. Adversarial attacks on deep learning models in smart grids. Energy Rep 2022;8:123–9.
[30] Lewis Patrick, Perez Ethan, Piktus Aleksandra, Petroni Fabio, Karpukhin Vladimir, Goyal Naman, Küttler Heinrich, Lewis Mike, Yih Wen-tau, Rocktäschel Tim, et al. Retrieval-augmented generation for knowledge-intensive nlp tasks. Adv Neural Inf Process Syst 2020;33:9459–74.
[31] Biggio Battista, Roli Fabio, et al. Wild patterns: Ten years after the rise of adversarial machine learning half-day tutorial. In: Proceedings of the ACM conference on computer and communications security. Association for Computing Machinery; 2018, p. 2154–6.
[32] Gu Tianyu, Liu Kang, Dolan-Gavitt Brendan, Garg Siddharth. Badnets: Evaluating backdooring attacks on deep neural networks. IEEE Access 2019;7:47230–44.
[33] Greshake Kai, Abdelnabi Sahar, Mishra Shailesh, Endres Christoph, Holz Thorsten, Fritz Mario. Not what you've signed up for: Compromising real-world llm-integrated applications with indirect prompt injection. In: Proceedings of the 16th ACM workshop on artificial intelligence and security. 2023, p. 79–90.
[34] Wang Youze, Hu Wenbo, Dong Yinpeng, Liu Jing, Zhang Hanwang, Hong Richang. Align is not enough: Multimodal universal jailbreak attack against multimodal large language models. IEEE Trans Circuits Syst Video Technol 2025.
[35] Wei Alexander, Haghtalab Nika, Steinhardt Jacob. Jailbroken: How does llm safety training fail? Adv Neural Inf Process Syst 2023;36:80079–110.
[36] Gao Jianxi, Barzel Baruch, Barabási Albert-László. Universal resilience patterns in complex networks. Nature 2016;530(7590):307–12.
[37] Segovia-Ferreira Mariana, Rubio-Hernan Jose, Cavalli Ana, Garcia-Alfaro Joaquin. A survey on cyber-resilience approaches for cyber-physical systems. ACM Comput Surv 2024;56(8):1–37.
[38] Chaudhary Aniket Karan, Roy Satyabrata, Guha Dipayan, Negi Richa, Banerjee Subrata. Adaptive cyber-tolerant finite-time frequency control framework for renewable-integrated power system under deception and periodic denial-of-service attacks. Energy 2024;302:131809.
[39] Cárdenas Alvaro A, Amin Saurabh, Lin Zong-Syun, Huang Yu-Lun, Huang Chi-Yen, Sastry Shankar. Attacks against process control systems: risk assessment, detection, and response. In: Proceedings of the 6th ACM symposium on information, computer and communications security. 2011, p. 355–66.
[40] Liang Gaoqi, Zhao Junhua, Luo Fengji, Weller Steven R, Dong Zhao Yang. A review of false data injection attacks against modern power systems. IEEE Trans Smart Grid 2016;8(4):1630–8.
[41] Costan Victor, Devadas Srinivas. Intel SGX explained. Cryptol EPrint Arch 2016.
[42] Cerdeira David, Santos Nuno, Fonseca Pedro, Pinto Sandro. Sok: Understanding the prevailing security vulnerabilities in trustzone-assisted tee systems. In: 2020 IEEE symposium on security and privacy. IEEE; 2020, p. 1416–32.
[43] Hu Wei, Ardeshiricham Armaiti, Kastner Ryan. Hardware information flow tracking. ACM Comput Surv 2021;54(4):1–39.
[44] Zhang Chen, Xie Yu, Bai Hang, Yu Bin, Li Weihong, Gao Yuan. A survey on federated learning. Knowl-Based Syst 2021;216:106775.
[45] Kairouz Peter, McMahan H Brendan, Avent Brendan, Bellet Aurélien, Bennis Mehdi, Bhagoji Arjun Nitin, Bonawitz Kallista, Charles Zachary, Cormode Graham, Cummings Rachel, et al. Advances and open problems in federated learning. Found Trends® Mach Learn 2021;14(1–2):1–210.

[46] Zhang Zikai, Rath Suman, Xu Jiahao, Xiao Tingsong. Federated learning for smart grid: A survey on applications and potential vulnerabilities. ACM Trans Cyber-Phys Syst 2024.
[47] Ali Mansoor, Kaddoum Georges, Li Wen-Tai, Yuen Chau, Tariq Muhammad, Poor H Vincent. A smart digital twin enabled security framework for vehicle-to-grid cyber-physical systems. IEEE Trans Inf Forensics Secur 2023;18:5258–71.
[48] Hardy Trevor D, Palmintier Bryan, Top Philip L, Krishnamurthy Dheepak, Fuller Jason C. HELICS: A co-simulation framework for scalable multi-domain modeling and analysis. IEEE Access 2024;12:24325–47.
[49] Arrieta Alejandro Barredo, Díaz-Rodríguez Natalia, Del Ser Javier, Bennetot Adrien, Tabik Siham, Barbado Alberto, García Salvador, Gil-López Sergio, Molina Daniel, Benjamins Richard, et al. Explainable artificial intelligence (XAI): Concepts, taxonomies, opportunities and challenges toward responsible AI. Inf Fusion 2020;58:82–115.
[50] Cifci Ahmet. Interpretable prediction of a decentralized smart grid based on machine learning and explainable artificial intelligence. IEEE Access 2025.
[51] Venzke Andreas, Chatzivasileiadis Spyros. Verification of neural network behaviour: Formal guarantees for power system applications. IEEE Trans Smart Grid 2020;12(1):383–97.